

Backend Architecture & Hardening: Case Ace v2.0

1. Minimal Endpoint Inventory & Attack Surface Minimisation

Every endpoint in a backend processing special category data is an attack surface, an audit liability, and a potential vector for exfiltration. The Case Ace v2.0 backend is architected as the absolute smallest service capable of supporting the system's privacy guarantees.

The 6 Permitted Endpoints

[!IMPORTANT]

Correction to the credential model. Earlier revisions described endpoint 2 as issuing "downscoped STS credentials" produced with a Credential Access Boundary. Google offers Credential Access Boundaries for Cloud Storage only; no other service supports them, so a boundary-scoped token for Speech-to-Text or Vertex AI cannot be created. The architecture rested on a capability that does not exist, and the implementation returned a random string formatted to look like a token, which authenticated nothing at all.

The same objective is now met by separating identities rather than constraining one token. Each purpose has its own service account holding a single role: case-ace-stt-sa with roles/speech.client, and case-ace-vertex-sa with roles/aiplatform.user. The runtime service account holds no API roles at all; it may only mint tokens for those two accounts, through IAM Credentials generateAccessToken.

Residual risk, stated plainly. The token handed to the browser is a full access token for a least-privilege service account, not a resource-scoped one. Within its short lifetime an attacker holding it could call that one API at CAW's expense. It could not read storage, reach another project, or touch any other service. The compensating controls are the short lifetime, the single role, the audit record written on every issuance, and the CSP connect-src allowlist. This is a real reduction against the boundary model that was described but never available, and it is recorded here rather than left implied.

Zero Session Data Guarantee

[!IMPORTANT]

Fundamental Privacy Rule: The backend contains zero endpoints for receiving, storing, querying, or returning client audio, transcripts, surrogate token maps, prompts, or case notes.

No database ORM exists. No session table exists. The backend is completely blind to client consultation content.

2. Ephemeral Scoped Credential Issuance

The client browser communicates directly with Google Cloud Speech-to-Text v2 (Chirp 2) and Vertex AI (Gemini 1.5 Pro) in europe-west2 (London) without routing payload data through the backend.

To prevent long-lived credential leakage:

No Long-Lived Service Account Keys: The client never holds, receives, or caches service account keys.

Short-Lived Ephemerality: Credentials expire in 300 seconds (5 minutes), with an absolute hard cap of 900 seconds (15 minutes).

Single-Purpose Downscoping:

purpose: 'speech-to-text' $\rightarrow$ Scoped strictly to <https://europe-west2-speech.googleapis.com>.

purpose: 'vertex-ai' $\rightarrow$ Scoped strictly to <https://europe-west2-aiplatform.googleapis.com>.

User & Role Binding: Only authenticated users with role adviser or supervisor can request cloud credentials. Requests from administrator or auditor roles are rejected with HTTP 403.

Audited Issuance Without Token Leakage:

The issuance event is logged with metadata (userId, role, purpose, ttlSeconds, region, timestamp).

The token string itself is NEVER written to logs, console output, or tracing spans.

3. Data Handling: Request & Response Body Logging Suppression

Default configurations in application frameworks, serverless runtimes (Cloud Run), and distributed tracing tools (OpenTelemetry, Cloud Trace) frequently log HTTP request and response payloads, headers, and query strings. In a privacy-preserving legal advice tool, this represents an intolerable risk of special category data leakage.

Technical Controls

Custom privacyLogger Middleware:

Intercepts all incoming HTTP requests and response completions.

Discards req.body and res.body entirely.

Discards query parameters (req.query) to eliminate accidental URL leakage.

Discards sensitive headers (Authorization, Cookie, X-Auth-*).

Emits only: { level, event: 'HTTP_REQUEST', method, path, statusCode, durationMs, timestamp }.

Platform & Tracing Defaults Hardened:

OpenTelemetry tracing is configured with payload capture disabled (capture_body: false).

Cloud Run request logging is isolated from stdout application logs.

Automated test suite (test/backend.test.ts) actively injects test payloads and asserts zero body leakage across all log streams.

4. UK Region Pinning & Infrastructure Hardening

All resources are pinned to europe-west2 (London, United Kingdom):

Cloud Run Backend: Configured in infrastructure/gcp/cloud-run.yaml with label cloud.google.com/location: europe-west2.

Cloud Speech-to-Text v2: Regional endpoint <https://europe-west2-speech.googleapis.com>.

Vertex AI Gemini: Regional endpoint <https://europe-west2-aiplatform.googleapis.com>.

Application Configuration: Hardcoded validation in backend/src/config/index.ts and client/src/config/environments.ts.